

What I Learned

This week, I explored the NIST Incident Response Lifecycle and the ethical principle of “minimum necessary.” The lifecycle includes six phases: Preparation, Detection & Analysis, Containment, Eradication, Recovery, and Lessons Learned. Each phase builds on the last to ensure incidents are handled quickly, ethically, and with respect for privacy and legal boundaries. Preparation ensures teams have defined roles and response playbooks. Detection relies on logs and indicators to identify issues early, while Containment aims to reduce damage without destroying evidence.

The importance of “minimum necessary” is emphasized throughout, particularly during evidence collection and containment. Over collection increases the risk of privacy violations and slows analysis. For example, collecting an entire mailbox is unnecessary if a single malicious email and a focused time window from the IdP are sufficient to confirm compromise. This aligns with the eBook’s harm prevention theme: help without creating more risk to users, organizations, or investigations.

How I’ll Apply It

Imagine a student on a campus reports a suspicious email claiming to be from IT, prompting password verification. As the technical owner, I would capture the raw .eml file of the email, including headers and body, and a 30 minute window of IdP login logs for the student’s account. These two artifacts are both minimal and sufficient to confirm whether credentials were harvested and misused. I would avoid collecting the student’s entire mailbox this would breach privacy, expand scope unnecessarily, and likely contain unrelated personal content. The scope and consent are limited to understanding the incident, not investigating the student.

Muddiest Point

My main question is about chain of custody: How is custody tracked in fast-moving incidents where multiple team members need to access evidence quickly? For example, if two analysts need to verify a log file within minutes of each other, does every access even for viewing require a separate custody row? Or is access logging handled by the storage system while chain of custody only documents transfers and edits? I want to ensure integrity without adding impractical delays.

Portfolio Note

- I will publish my **Incident & Evidence Note** from the in-class phishing exercise.
- It demonstrates my ability to act ethically, document cleanly, and make containment recommendations grounded in evidence.